Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Baykal APHS'nin kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: üst çene ile kalıp arasında el-parmak ezilmesi, sacın geri tepmesi / savrulması.*

Görev — üç senaryo kurun ve puanlayın

(Formül: Skor = L × S × E [Her biri 1-3] | Kural: S=3 ise skor düşük olsa bile öncelik en yüksektir.)

Senaryo (kim → kapı → ne yapar → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
Dış Saldırgan → İnternete Açık Uzak Bakım Modülü (Admin/Admin Parolası) → CNC Lazer Koruma Parametrelerini Değiştirir → Işık Bariyeri Devre Dışı Kalır → Operatörün Elleri Üst Çene Altında Ezilir (Kritik Fiziksel Yaralanma).	2 (Ağ üzerinden erişim riski yüksek)	3 (Ölümcül / Ağır uzuv kaybı)	2 (Vardiya boyunca makine sürekli çalışıyor)	2 × 3 × 2 = 12 (Yüksek / Kritik)	1 (En Yüksek)
Kötü Niyetli İç Personel → Kilitsiz USB / Zayıf Wi-Fi Ağı → Zararlı Script Yükler → Normal PLC Büküm Basıncını ve Hızını Maksimuma Çıkarır → Hidrolik Valf Blokajı / Gövde Patlaması → Saçılan Parçalar Operatöre Şiddetli Darbe Verir.	1 (Fiziksel veya yerel ağ erişimi gerektirir)	3 (Fiziksel yaralanma / travmatik darbe)	1 (Nadir yapılan USB veri yüklemesi)	1 × 3 × 1 = 3 (Düşük Skor)	2 (S=3 kuralı gereği skor düşük olsa da insana zarar vereceği için öne alınır)
Yetkisiz Kullanıcı → Port 80 HMI (Web Arayüzü) → Arka Dayama Eksen (X, R, Z) Koordinatlarını Bozar → Sac Levha Hatası ve Geri Tepme Oluşur → Operatöre Çarparak Travmatik Fiziksel Hasar Oluşturur.	2 (Ağ üzerinden şifresiz HMI erişimi)	2 (Orta düzey fiziksel darbe / ezilme)	2 (Günlük üretim boyunca aktif)	2 × 2 × 2 = 8	3

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryo hangisi? Bir cümleyle: neden bu?

   En yüksek öncelikli senaryo 1 numaralı senaryodur; çünkü internete açık uzak bakım modülü ve varsayılan zayıf parola (admin/admin) üzerinden sızan bir saldırganın doğrudan lazer koruma bariyerini devre dışı bırakarak S=3 (ölümcül ezilme riski) seviyesinde fiziksel yıkım üretmesi en büyük tehdittir.s

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, 2 numaralı senaryoda Olasılık (L=1) ve Maruz Kalma (E=1) düşük olduğu için toplam skor 3 çıkmıştır; ancak Şiddet seviyesi (S=3) insana doğrudan zarar vereceği için kritik risk taşır. Bunu risk matrisinde ve raporda “Düşük Olasılıklı Fakat Felaket Senaryosu (High-Impact Low-Frequency)” olarak etiketleyip rengini kırmızıya çekerek görünür kılacağız.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.